

CO 2_AT 1_Report Analysis

Question 1 : A security analyst performed a network scan on the target 192.168.1.10 using the Nmap tool. The report identified several open ports, including HTTP (80), SSH (22), and MySQL (3306), along with the operating system and service versions. Analyze the report and explain the security risks associated with the identified services. Discuss how an attacker could exploit these services and recommend suitable security measures to protect the target system.

Analysis of the Nmap Report

The Nmap scan performed on the target system **192.168.1.10** identified the following open ports:

Port Service Purpose

22 SSH Secure remote login and administration

80 HTTP Hosts websites and web applications

3306 MySQL Database management service

The report also identified the operating system and service versions running on the target.

Security Risks

1. SSH (Port 22)

SSH provides secure remote access to the system.

Risks:

- Weak or default passwords may allow brute-force attacks.
- Outdated SSH versions may contain known vulnerabilities.
- Misconfigured SSH settings may allow unauthorized access.

Possible Attacks

- Password brute-force attack.
- Credential stuffing.
- Exploitation of SSH software vulnerabilities.
- Unauthorized remote login if credentials are compromised.

2. HTTP (Port 80)

HTTP is used to host websites and web applications.

Risks:

- Communication is not encrypted.

- Sensitive information can be intercepted.
- Vulnerable web applications may allow attacks.

Possible Attacks

- SQL Injection
- Cross-Site Scripting (XSS)
- Cross-Site Request Forgery (CSRF)
- Directory Traversal
- Session Hijacking

3. MySQL (Port 3306)

MySQL stores application and user data.

Risks

- Weak database passwords.
- Database exposed to the public network.
- Unpatched database software.

Possible Attacks

- Database login using stolen credentials.
- SQL Injection to access confidential data.
- Data theft or modification.
- Privilege escalation.

Operating System Information

The Nmap report also reveals the operating system and service versions.

Security Risk

Attackers can:

- Identify known vulnerabilities.
- Search public exploit databases.
- Use vulnerability scanners against the identified version.

This helps attackers prepare targeted attacks.

How an Attacker Could Exploit These Services

An attacker may follow these steps:

1. Perform Nmap reconnaissance.

2. Identify open ports and services.
3. Search for known vulnerabilities in the detected versions.
4. Launch brute-force attacks against SSH.
5. Exploit web application vulnerabilities on HTTP.
6. Attempt SQL Injection to access the MySQL database.
7. Gain unauthorized access and steal confidential information.
8. Maintain persistence inside the system.

Recommended Security Measures

SSH Security

- Use strong passwords.
- Enable Multi-Factor Authentication (MFA).
- Disable root login.
- Use SSH keys instead of passwords.
- Limit login attempts.
- Allow SSH access only from trusted IP addresses.

HTTP Security

- Use HTTPS instead of HTTP.
- Install SSL/TLS certificates.
- Keep web applications updated.
- Validate all user inputs.
- Deploy a Web Application Firewall (WAF).

MySQL Security

- Restrict database access.
- Use strong database passwords.
- Disable remote database access if unnecessary.
- Encrypt sensitive data.
- Regularly update MySQL.

General Recommendations

- Configure firewalls.
- Perform regular vulnerability assessments.

- Apply security patches promptly.
- Enable intrusion detection systems.
- Monitor logs continuously.
- Conduct regular security audits.

Command:

```
nmap -A 192.168.1.10
```

Explanation:

- nmap → Starts the Nmap tool.
- -A → Performs an aggressive scan (OS detection, service version detection, script scanning, and traceroute).
- 192.168.1.10 → Target IP address.

Alternative Commands:

```
nmap -sV 192.168.1.10
```

(Service version detection)

```
nmap -O 192.168.1.10
```

(Operating system detection)

```
nmap -p 22,80,3306 192.168.1.10
```

(Scan only specific ports)

Conclusion

The Nmap report shows that SSH, HTTP, and MySQL services are running on the target system. If these services are not properly secured, attackers can exploit vulnerabilities to gain unauthorized access, steal sensitive information, and compromise the system. Implementing strong authentication, secure configurations, regular updates, and continuous monitoring significantly improves the overall security posture.

Question 2 : A phishing awareness campaign was conducted for employees of ABC Technologies Pvt. Ltd. Using the GoPhish tool. The report indicates that 40% of employees clicked the phishing link, 20% entered their login credentials, and several users downloaded a malicious attachment. Analyze the report and identify the security weaknesses demonstrated by the employees. Recommend suitable user awareness programs, email security controls, and organizational policies to reduce the risk of successful social engineering attacks.

Analysis of the GoPhish Report

The phishing awareness campaign produced the following results:

- **40%** of employees clicked the phishing link.

- **20%** entered their login credentials.
- Several employees downloaded a malicious attachment.

These results indicate that many employees were vulnerable to phishing attacks.

Security Weaknesses Identified

1. Employees Clicked Phishing Links

This indicates:

- Lack of awareness about suspicious emails.
- Failure to verify sender identity.
- Poor understanding of phishing indicators.

2. Employees Entered Login Credentials

This indicates:

- Employees trusted fake login pages.
- Lack of awareness regarding credential theft.
- Weak verification practices.

3. Employees Downloaded Malicious Attachments

This demonstrates:

- Unsafe handling of email attachments.
- Lack of malware awareness.
- Increased risk of ransomware infection.

Potential Security Risks

The successful phishing attack may lead to:

- Credential theft
- Unauthorized system access
- Identity theft
- Malware infection
- Ransomware attacks
- Financial fraud
- Data breaches
- Business disruption

Recommended User Awareness Programs

Organizations should conduct:

- Regular phishing awareness training.
- Simulated phishing campaigns.
- Cybersecurity workshops.
- Password security awareness.
- Safe email handling training.
- Social engineering awareness sessions.
- Incident reporting training.

Employees should learn to:

- Verify sender email addresses.
- Avoid clicking suspicious links.
- Report suspicious emails immediately.
- Never share passwords.
- Verify unexpected requests.

Recommended Email Security Controls

The organization should implement:

- Email spam filtering.
- Anti-phishing gateways.
- Attachment scanning.
- URL filtering.
- Multi-Factor Authentication (MFA).
- Email encryption.
- SPF, DKIM, and DMARC.
- Malware detection systems.

Organizational Policies

The organization should establish:

- Acceptable Email Usage Policy.
- Password Policy.
- Information Security Policy.
- Incident Response Policy.

- Security Awareness Policy.
- Data Protection Policy.

Regular compliance audits should also be conducted.

To start GoPhish:

`./gophish`

Or, if installed as a service:

`sudo systemctl start gophish`

Then open:

`https://127.0.0.1:3333`

Log in and:

1. Create users.
2. Create an email template.
3. Create a landing page.
4. Create a sending profile.
5. Launch the campaign.
6. View the generated report (click rate, credential submission rate, etc.).

Conclusion

The GoPhish report reveals that employees remain vulnerable to phishing attacks. Continuous awareness training, advanced email security controls, Multi-Factor Authentication, and strong organizational policies are essential to reduce the risk of successful social engineering attacks and improve the organization's overall cybersecurity posture.

Question 3 : A DNS assessment report generated using the Dig tool shows that the organization's DNS server permits a successful DNS Zone Transfer (AXFR), exposing internal hostnames, mail servers, and DNS records. Analyze the report and explain the security implications of the exposed information. Discuss how attackers could exploit these findings and recommend best practices to secure the DNS infrastructure.

Analysis of the DNS Assessment Report

The Dig assessment report shows that the organization's DNS server allows **DNS Zone Transfer (AXFR)**.

A DNS Zone Transfer is intended to synchronize DNS records between primary and secondary DNS servers. If unrestricted, unauthorized users can obtain the complete DNS database.

Information Exposed

The successful zone transfer reveals:

- Internal hostnames
- Mail server details
- DNS records
- Server names
- IP addresses
- Subdomains

This information provides attackers with a detailed map of the organization's network.

Security Implications

Allowing unrestricted AXFR exposes sensitive infrastructure information.

Potential consequences include:

- Network reconnaissance
- Identification of critical servers
- Easier attack planning
- Discovery of internal systems
- Increased phishing opportunities
- Information disclosure
- Higher risk of targeted cyberattacks

How Attackers Could Exploit the Information

An attacker may:

1. Perform DNS Zone Transfer.
2. Collect all DNS records.
3. Identify mail servers.
4. Discover internal systems.
5. Launch phishing attacks against employees.
6. Scan identified hosts for vulnerabilities.
7. Target exposed servers.
8. Gain unauthorized access to the network.

Best Practices to Secure DNS Infrastructure

- Disable unrestricted DNS Zone Transfers.

- Allow AXFR only between authorized DNS servers.
- Restrict zone transfers using IP address filtering.
- Enable DNSSEC to ensure DNS data integrity.
- Regularly update DNS software.
- Monitor DNS logs for suspicious activity.
- Implement firewalls and access control lists (ACLs).
- Perform regular DNS security audits.
- Remove unnecessary DNS records.
- Use network segmentation for critical DNS infrastructure.

Command:

```
dig AXFR example.com
```

Example:

```
dig AXFR tesla.com
```

or

```
dig @ns1.example.com example.com AXFR
```

Explanation:

- dig → DNS lookup tool.
- AXFR → Requests a DNS zone transfer.
- @ns1.example.com → Specifies the DNS server.
- example.com → Target domain.

Conclusion

The Dig report indicates a serious DNS misconfiguration by allowing unrestricted DNS Zone Transfers. This exposes valuable network information that attackers can use during reconnaissance. Restricting AXFR, implementing DNSSEC, maintaining secure DNS configurations, and continuously monitoring DNS activity are essential to protect the organization's infrastructure from reconnaissance and subsequent cyberattacks.